acceptable use policy/rules of behavior Agreed-upon principles set forth by a company to govern how the employees of that company may use resources such as computers and Internet access.

annual loss expectancy (ALE) A calculation used to identify risks and calculate the expected loss each year.

annualized rate of occurrence (ARO) A calculation of how often a threat will occur. For example, a threat that occurs once every five years has an annualized rate of occurrence of 1/5, or 0.2.

asset value (AV) The assessed value of an item (server, property, and so on) associated with cash flow.

business impact analysis (BIA) A study of the possible impact if a disruption to a business's vital resources were to occur.

business partners agreement (BPA) An agreement between partners in a business that outlines their responsibilities, obligations, and sharing of profits and losses.

exposure factor (EF) The potential percentage of loss to an asset if a threat is realized.

interconnection security agreement (ISA) As defined by NIST (in Publication 800-47), it is "an agreement established between the organizations that own and operate connected IT systems to document the technical requirements of the interconnection. The ISA also supports a Memorandum of Understanding or Agreement (MOU/A) between the organizations."

maximum tolerable downtime (MTD) The maximum period of time that a business process can be down before the survival of the organization is at risk.

mean time between failures (MTBF) The measurement of the anticipated lifetime of a system or component.

mean time to failure (MTTF) The measurement of the average of how long it takes a system or component to fail.

mean time to restore (MTTR) The measurement of how long it takes to repair a system or component once a failure occurs.

memorandum of understanding (MOU)/memorandum of agreement (MOA) Most commonly known as an MOU rather than MOA, this is a document between two or more parties defining their respective responsibilities in accomplishing a particular goal or mission, such as securing a system.

recovery point objective (RPO) The point last known good data prior to an outage that is used to recover systems.

recovery time objective (RTO) The maximum amount of time that a process or service is allowed to be down and the consequences still to be considered acceptable.

Redundant Array of Independent Disks (RAID) A configuration of multiple hard disks used to provide fault tolerance should a disk fail. Different levels of RAID exist.

risk The probability that a particular threat will occur, either accidentally or intentionally, leaving a system vulnerable and the impact of this occurring.

risk acceptance A strategy of dealing with risk in which it is decided the best approach is simply to accept the consequences should the threat happen.

risk analysis An evaluation of each risk that can be identified. Each risk should be out- lined, described, and evaluated on the likelihood of it occurring.

risk assessment An evaluation of the possibility of a threat or vulnerability existing. An assessment must be performed before any other actions—such as how much to spend on security in terms of dollars and manpower—can be decided.

risk avoidance A strategy of dealing with risk in which it is decided that the best approach is to avoid the risk.

risk calculation The process of calculating the risks that exist in terms of costs, number, frequency, and so forth.

risk deterrence A strategy of dealing with risk in which it is decided that the best approach is to discourage potential attackers from engaging in the behavior that leads to the risk.

risk mitigation A strategy of dealing with risk in which it is decided that the best approach is to lessen the risk.

risk transference A strategy of dealing with risk in which it is decided that the best approach is to offload some of the risk through insurance, third-party contracts, and/or shared responsibility.

service-level agreement (SLA) An agreement that specifies performance requirements for a vendor. This agreement may use mean time before failure (MTBF) and mean time to repair (MTTR) as performance measures in the SLA.

single loss expectancy (SLE) The cost of a single loss when it occurs. This loss can be a critical failure, or it can be the result of an attack.

single point of failure (SPOF) A single weakness that is capable of bringing an entire system down

vulnerability A flaw or weakness in some part of a system's security procedures, design, implementation, or internal controls that could expose it to danger (accidental or intentional) and result in a violation of the security policy.

demilitarized zone (DMZ) A network segment between two firewalls. One is outward facing, connected to the outside world, the other inward facing, connected to the internal network. Public-facing servers, such as web servers, are often placed in a DMZ.

honeynet A network that functions in the same manner as a honeypot.

honeypot A fake system designed to divert attackers from your real systems. It is often replete with logging and tracking to gather evidence.

information security management system (ISMS) A broad term that applies to a wide range of systems used to manage information security.

intrusion detection system (IDS) A system that monitors the network for possible intrusions and logs that activity.

intrusion prevention system (IPS) A system that monitors the network for possible intrusions and logs that activity and then blocks the traffic that is suspected of being an attack.

personally identifiable information (PII) Any information that could identify a particular individual.

software-defined network (SDN) The entire network, including all security devices, is virtualized.

stateful packet inspection (SPI) A firewall that not only examines each packet but also remembers the recent previous packets.

access control list (ACL) A table or data file that specifies whether a user or group has access to a specific resource on a computer or network.

access point (AP) The point at which access to a network is accomplished. This term is often used in relation to a wireless access point.

active response A response generated in real time.

alarm A notification that an unusual condition exists and should be investigated.

alert An indication that an unusual condition could exist and should be investigated.

all-in-one appliance An appliance that performs multiple functions.

analyzer The component or process that analyzes the data collected by the sensor.

anomalies Variations from normal operations.

anomaly-detection IDS (AD-IDS) An anomaly-detection intrusion detection system works by looking for deviations from a pattern of normal network traffic.

appliance A freestanding device that operates in a largely self-contained manner.

application-level proxy A device or software that recognizes application-specific com- mands and offers granular control over them.

Authentication Header (AH) An IPSec header used to provide connectionless integrity and data origin authentication for IP datagrams and to provide protection against replays.

clustering A method of balancing loads and providing fault tolerance.

compensating controls Gap controls that fill in the coverage between other types of vulnerability mitigation techniques (where there are holes in coverage, we compensate for them).

data loss prevention (DLP) Any systems that identify, monitor, and protect data to pre- vent it from unauthorized use, modification, destruction, egress, or exfiltration from a location.

Encapsulating Security Payload (ESP) An IPSec header used to provide a mix of security services in IPv4 and IPv6. ESP can be used alone or in combination with the IP Authentication Header (AH).

encapsulation The process of enclosing data in a packet.

false negative An event that should be flagged but isn't.
false positive A flagged event that isn't really an event and has been falsely triggered.

firewall A combination of hardware and software filters placed between trusted and untrusted networks intended to protect a network from attack by hackers who could gain access through public networks, including the Internet.

host-based IDS (HIDS) An intrusion detection system that is host based. An alternative is an intrusion detection system that is network based.

HSM (hardware security module) A software or appliance stand-alone used to enhance security and commonly used with PKI systems.

implicit deny A condition that states that unless otherwise given, the permission will be denied.

Internet Protocol Security (IPSec) A set of protocols that enable encryption, authentication, and integrity over IP. IPSec is commonly used with virtual private networks (VPNs) and operates at Layer 3.

intrusion detection system (IDS) Tools that identify attacks using defined rules or logic and are considered passive. An IDS can be network based or host based.

intrusion prevention system (IPS) Tools that respond to attacks using defined rules or logic and are considered active. An IPS can be network based or host based.

key management The management of all aspects of cryptographic keys in a cryptosystem, including key generation, exchange, storage, use, destruction and replacement.

load balancing Dividing a load for greater efficiency of management among multiple devices.

network access control (NAC) The set of standards defined by the network for clients attempting to access it. Usually, NAC requires that clients be virus free and adhere to specified policies before allowing them on the network.

network intrusion prevention system (NIPS) An intrusion prevention system that is net- work based.

network-based IDS (NIDS) An approach to an intrusion detection system (IDS); it attaches the system to a point in the network where it can monitor and report on all network traffic.

passive response A nonactive response, such as logging. Passive response is the most common type of response to many intrusions. In general, passive responses are the easiest to develop and implement.

proxy A type of system that prevents direct communication between a client and a host by acting as an intermediary.

proxy firewall A proxy server that also acts as a firewall, blocking network access from external networks.

proxy server A type of server that makes a single Internet connection and services requests on behalf of many users.

Secure Sockets Layer (SSL) A protocol that secures messages by operating between the Application layer (HTTP) and the Transport layer.

SIEM Security information and event management (SIEM) software combines security information management (SIM) and security event management (SEM) functions to provide real-time analysis of security alerts.

signature-based system A system that acts based on the digital signature it sees and offers no repudiation to increase the integrity of a message.

SSID broadcast An access point's broadcasting of the network name.

stateful inspection Inspections that occur at all levels of the network and provide additional security using a state table that tracks every communications channel.

switch A network device that can replace a router or hub in a local network and get data from a source to a destination. Switching allows for higher speeds.

Challenge Handshake Authentication Protocol (CHAP) An authentication protocol that periodically reauthenticates.

crossover error rate (CER) The point at which the FRR and FAR are equal. Sometimes called the *equal error rate (ERR)*.

data execution prevention (DEP) Any technique that prevents a program from running without the user's approval.

data loss prevention (DLP) Software or techniques designed to detect attempts to exfiltrate data.

false acceptance rate (FAR) The rate at which a biometric solution allows in individuals it should have rejected.

false rejection rate (FRR) The rate at which a biometric solution rejects individuals it should have allowed.

federation A collection of computer networks that agree on standards of operation, such as security standards.

HIDS A host-based intrusion detection system. An HIPS is a host-based intrusion prevention system.

Kerberos An authentication protocol developed at MIT that uses tickets for authentication.

least privileges The principle that any user or service will be given only enough access privileges to do its job and no more.

NIDS A network-based intrusion detection system. An NIPS is an intrusion prevention system. Unlike an HIDS/HIPS, an NIDS/NIPS scans an entire network segment.

network scanner A tool that enumerates your network and provides a map of the network.

OAUTH Open Authorization standard. It is a common method for authorizing websites or applications to access information.

802.1x The IEEE standard that defines port-based security for wireless network access control.

access point (AP) The point at which access to a network is accomplished. This term is often used in relation to a wireless access point (WAP).

bluejacking The sending of unsolicited messages over a Bluetooth connection.

bluesnarfing The gaining of unauthorized access through a Bluetooth connection.

disassociation An attack in which the intruder sends a frame to the AP with a spoofed address to make it look like it came from the victim and disconnects them from the network.

evil twin An attack in which a rogue wireless access point poses as a legitimate wireless service provider to intercept information that users transmit.

interference The byproduct of electrical processes. One common form of interference is Radio Frequency Interference (RFI), which is usually projected across a radio spectrum.

IV attack An attack that involves looking at repeated results in order to crack the WEP secret key.

jamming Purposely obstructing or interfering with a signal.

near field communication (NFC) Technology that enables communication between devices when they're "touched" together. Often used to verify (often through RFID or Wi-Fi) that the device is present.

radio frequency identification (RFID) A technology that incorporates the use of electromagnetic coupling in the radio frequency (RF) portion of the spectrum to identify items uniquely (object, animal, person, credit cards, door access tokens, antishoplifting devices, and so on).

replay attack An attack that captures portions of a session to play back later to convince a host that it is still talking to the original connection.

rogue access point An unauthorized wireless access point on a network.

SSID The Service Set Identifier (SSID) is used by the access point of a wireless LAN to identify itself and is intended to be unique for a particular area/entity on a network.

Wi-Fi A wireless network operating in the 2.4 GHz or 5 GHz range.

Wi-Fi Protected Setup (WPS) An authentication process that requires the user to do something in order to complete the enrollment process. Examples include pressing a button on the router within a short time period, entering a PIN, or bringing the new device close.

Wired Equivalent Privacy (WEP) A security protocol for 802.11b (wireless) networks that attempts to establish the same security for them as would be present in a wired network.

wireless access point A connection device used for clients in a radio frequency (RF) network.

cloud access security broker On-premise or cloud-based security policy enforcement points.

cloud bursting Moving the execution of an application to the cloud on an as-needed basis.

cloud computing A model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources.

community cloud Cloud delivery model in which the infrastructure is shared by organizations with something in common.

hybrid cloud Any cloud delivery model that combines two or more of the other delivery model types.

hypervisor The software that allows virtual machines to exist. The machine running the hypervisor is known as a host, while the instances of virtual machines are known as guests.

Infrastructure as a Service (IaaS) A model of cloud computing that utilizes virtualization; clients pay an outsourcer for the resources used.

National Institute of Standards and Technology (NIST) An agency (formerly known as the National Bureau of Standards [NBS]) that has been involved in developing and sup- porting standards for the U.S. government for over 100 years. NIST has become involved in cryptography standards, systems, and technology in a variety of areas. It's primarily concerned with governmental systems, where it exercises a great deal of influence.

Platform as a Service (PaaS) A cloud service model wherein the consumer can deploy but does not manage or control any of the underlying cloud infrastructure.

private cloud A cloud delivery model owned and managed internally.

public cloud A cloud delivery model available to others.

QoS (quality of service) A collection of technologies that provide the ability to balance network traffic and prioritize workloads.

sandboxing Isolating applications to keep users of them from venturing to other data.

Security as a Service A subscription-based business model intended to be more cost effective than smaller individuals/corporations could ever achieve on their own.

Software as a Service (SaaS) A model of cloud computing in which the consumer can use the provider's applications, but they do not manage or control any of the underlying cloud infrastructure.

Type I hypervisor Virtualization method that is independent of the operating system and boots before the OS.

Type II hypervisor Virtualization method that is dependent on the operating system.

VDE A virtual desktop environment (VDE) stores everything related to the user (wall-paper, folders, windows, and so on) remotely and client software locally simulates the user's desktop environment and capabilities while running them on the host.

VDI Virtual desktop infrastructure (VDI) is the process of running a user desktop inside a virtual machine that lives on a server in the datacenter. It enables fully personalized desktops for each user yet maintains centralized management and security.

virtualization Emulating one or more physical computers on the same host.

VM escape The act of breaking out of one virtual machine into one or more others on the same physical host.

VM sprawl Growth that occurs on a large number of virtual machines and requires resources—usually administration related—to keep up with.

advanced persistent threats (APTs) Any sophisticated series of related attacks taking place over an extended period of time.

Agile development A method of software development meant to be rapid.

baselining Creating a fundamental, or baseline, security level.

Big Data Data that is larger than what can be handled with traditional tools and algorithms.

database normalization The process of removing duplication in a relational database.

embedded system Operating system in a device, sometimes on a single chip.

fuzzing A method of testing that intentionally enters invalid input to see if the application can handle it.

hardening The process of making a server or an application resistant to an attack.

Infrastructure as Code (IaC) The process of managing and provisioning computer data- centers through machine-readable definition files.

Internet of Things (IoT) Devices that interact on the Internet, without human intervention.

NoSQL database Datastores that do not use a relational structure.

Open Web Application Security Project (OWASP) An online community that develops free articles, documentation, tools, and more on web application security.

prototyping Creating a version of an application that has only the bare minimum functionality so that it can be evaluated before further development.

sandboxing Operating in an isolated environment. **script kiddy** An attacker with very minimal skills. **secure coding** Programming in a manner that is secure.

stored procedures SQL statements written and stored on the database that can be called by applications.

stress testing Subjecting a system to workloads that are extreme.

Structured Query Language (SQL) The language used by all relational databases.

waterfall method A software development method that uses very well-defined sequential phases.

zero-day exploit A vulnerability that is unknown to the product vendor, and thus there is no patch for it.

asymmetric cipher Cryptographic algorithms that use two different keys—one key to

encrypt and another to decrypt. Also called public key cryptography.

Challenge Handshake Authentication Protocol (CHAP) An authentication protocol that periodically reauthenticates.

collision When two different inputs into a cryptographic hash produce the same output, this is known as a collision.

cryptographic hash A function that is one-way (nonreversible), has a fixed length output, and is collision resistant.

PRNG A pseudo-random number generator is an algorithm used to generate a number that is sufficiently random for cryptographic purposes.

rainbow table A table of precomputed hashes used to guess passwords by searching for the hash of a password.

salt Bits added to a hash to make it resistant to rainbow table attacks.

symmetric cipher Any cryptographic algorithm that uses the same key to encrypt and decrypt. DES, AES, and Blowfish are examples.

X.509 The X.509 standard is the most widely used standard for digital certificates.

Address Resolution Protocol (ARP) Protocol used to map known IP addresses to unknown physical addresses.

Address Resolution Protocol (ARP) poisoning An attack that convinces the network that the attacker's MAC (Media Access Control) address is the one associated with an allowed address so that traffic is wrongly sent to attacker's address.

adware Software that gathers information to pass on to marketers or that intercepts personal data such as credit card numbers and makes it available to third parties.

antivirus software Software that identifies the presence of a virus and is capable of removing or quarantining the virus.

armored virus A virus that is protected in a way that makes disassembling it difficult. The difficulty makes it "armored" against antivirus programs that have trouble getting to, and understanding, its code.

ARP spoofing More commonly known as ARP poisoning, this involves the MAC (Media Access Control) address of the data being faked.

attack Any unauthorized intrusion into the normal operations of a computer or computer network. The attack can be carried out to gain access to the system or any of its resources.

attack surface The area of an application that is available to users—those who are authenticated and, more importantly, those who are not.

attack surface reduction (ASR) Minimizing the possibility of exploitation by reducing the amount of code and limiting potential damage.

backdoor An opening left in a program application (usually by the developer) that allows additional access to data. Typically, a backdoor is created for debugging purposes and is not documented. Before the product ships, the backdoors are closed; when they aren't closed, security loopholes exist.

bot An automated software program (network robot) that collects information on the web. In its malicious form, a bot is a compromised computer being controlled remotely.

buffer overflow A type of denial-of-service (DoS) attack that occurs when more data is put into a buffer than it can hold, thereby overflowing it (as the name implies).

clickjacking Using multiple transparent or opaque layers to trick a user into clicking a button or link on another page when they had intended to click on the top page.

companion virus A virus that creates a new program that runs in the place of an expected program of the same name.

cross-site request forgery (XSRF) A form of web-based attack in which unauthorized commands are sent from a user that a website trusts.

cross-site scripting (XSS) Running a script routine on a user's machine from a website without their permission.

denial-of-service (DoS) A type of attack that prevents any users—even legitimate ones— from using a system.

dictionary attack The act of attempting to crack passwords by testing them against a list of dictionary words. With today's powerful computers, an attacker can combine one of many available automated password-cracking utilities with several large dictionaries or "wordlists" and crack huge numbers of passwords in a matter of minutes. Any password based on any dictionary word is vulnerable to such an attack.

distributed denial-of-service (DDoS) A derivative of a DoS attack in which multiple hosts in multiple locations all focus on one target to reduce its availability to the public. This can be accomplished through the use of compromised systems, botnets, and other means.

DNS poisoning An attack method in which a daemon caches DNS reply packets, which sometimes contain other information (data used to fill the packets). The extra data can be scanned for information useful in a break-in or man-in-the-middle attack.

DNS spoofing The DNS server is given information about a name server that it thinks is legitimate when it isn't.

Domain Name System (DNS) The network service used in TCP/IP networks that translates hostnames to IP addresses.

integer overflow Putting too much information into too small of a space that has been set aside for numbers.

IP spoofing Making the data look as if it came from a trusted host when it didn't (thus spoofing the IP address of the sending host).

least privilege A permission method in which users are granted only the privileges necessary to perform their job function.

least privilege policy The policy of giving a user only the minimum permissions needed to do the work that must be done.

logic bomb Any code that is hidden within an application and causes something unexpected to happen based on some criteria being met. For example, a programmer could create a program that always makes sure her name appears on the payroll roster; if it doesn't, then key files begin to be erased.

macro virus A software exploitation virus that works by using the macro feature included in many applications, such as Microsoft Office.

malicious code Any code that is meant to do harm.

malicious insider threat A threat from someone inside the organization intent on doing harm.

man-in-the-middle An attack that occurs when someone/something that is trusted intercepts packets and retransmits them to another party. Man-in-the-middle attacks have also been called TCP/IP hijacking in the past.

multipartite virus A virus that attacks a system in more than one way.

password attacks Attempting to ascertain a password that you should not know.

phage virus A virus that modifies and alters other programs and databases.

ping of death A large Internet Control Message Protocol (ICMP) packet sent to overflow the remote host's buffer. A ping of death usually causes the remote host to reboot or hang.

polymorphic An attribute of some viruses that allows them to mutate and appear differently each time they crop up. The mutations make it harder for virus scanners to detect (and react) to the viruses.

privilege escalation The result when a user obtains access to a resource that they wouldn't normally be able to access. Privilege escalation can be done inadvertently by running a program with Set User ID (SUID) or Set Group ID (SGID) permissions or by temporarily becoming another user (via su or sudo in Unix/Linux or RunAs in Windows). It can also be done purposefully by an attacker seeking full access.

ransomware Software that demands payment before restoring the data or system infected.

replay attack An attack that captures portions of a session to play back later to convince a host that it is still talking to the original connection.

retrovirus A virus that attacks or bypasses the antivirus software installed on a computer.

rogueware A form of malware that tries to convince the user to pay for a fake threat.

rootkit Software program that has the ability to obtain root-level access and hide certain things from the operating system.

scareware Software that tries to convince unsuspecting users that a threat exists.

shim A small library that is created to intercept API calls transparently.

spoofing An attempt by someone or something to masquerade as someone/something else.

spyware Software programs that work—often actively—on behalf of a third party.

stealth virus A virus that attempts to avoid detection by masking itself from applications.

Trojan horse Any application that masquerades as one thing in order to get past scrutiny and then does something malicious. One of the major differences between Trojan horses and viruses is that Trojan horses tend not to replicate themselves.

typo squatting Creating domains that are based on the misspelling of another.

URL hijacking Registering domains that are similar to those for a known entity but based on a misspelling or typographical error.

virus A program intended to damage a computer system.

watering hole attack Identifying a site that is visited by those whom they are targeting, poisoning that site, and then waiting for the results.

Xmas attack An advanced attack that tries to get around detection and send a packet with every single option enabled.

zero-day exploit An attack that begins the very day an exploit is discovered.

zombie Any system taking directions from a master control computer. Zombies are often used in distributed denial-of-service (DDoS) and botnet attacks.

administrative control A control implemented through administrative policies or procedures.

cable lock A physical security deterrent used to protect a computer.

cold aisles Server room aisles that blow cold air from the floor.

compensating controls Gap controls that fill in the coverage between other types of vulnerability mitigation techniques. (Where there are holes in coverage, we compensate for them.)

control Processes or actions used to respond to situations or events.

control types Technical, physical, or administrative measures in place to assist with resource management.

data disposal Getting rid of/destroying media no longer needed.

detective control Controls that are intended to identify and characterize an incident in progress (for example, sounding the alarm and alerting the administrator).

dumpster diving Looking through trash for clues—often in the form of paper scraps—to find users' passwords and other pertinent information.

Faraday cage An electrically conductive wire mesh or other conductor woven into a "cage" that surrounds a room and prevents electromagnetic signals from entering or leaving the room through the walls.

fire suppression The act of stopping a fire and preventing it from spreading.

hoax Typically, an email message warning of something that isn't true, such as an outbreak of a new virus. A hoax can send users into a panic and cause more harm than the virus.

hot aisles A server room aisle that removes hot air.

impersonation Pretending to be another person to gain information.

information classification The process of determining what information is accessible, to what parties, and for what purposes.

mantrap A device, such as a small room, that limits access to one or a few individuals. Mantraps typically use electronic locks and other methods to control access.

PASS method The correct method of extinguishing a fire with an extinguisher: Pull, Aim, Squeeze, and Sweep.

perimeter security Security set up on the outside of the network or server to protect it.

Personal Identity Verification (PIV) Card required of federal employees and contractors to gain access (physical and logical) to government resources.

personally identifiable information (PII) Information that can be uniquely used to identify, contact, or locate a single person. Examples include Social Security number, driver's license number, fingerprints, and handwriting.

phishing A form of social engineering in which you simply ask someone for a piece of information that you are missing by making it look as if it is a legitimate request. Commonly sent via email.

physical controls Controls and countermeasures of a tangible nature intended to minimize intrusions.

preventive controls Controls intended to prevent attacks or intrusions.

privacy A state of security in which information isn't seen by unauthorized parties without the express permission of the party involved.

privacy filters Screens that restrict viewing of monitors to only those sitting in front of them.

PTZ Cameras that can pan, tilt, and zoom.

restricted information Information that isn't made available to all and to which access is granted based on some criteria.

shoulder surfing Watching someone when they enter their username, password, or sensitive data.

social engineering An attack that uses others by deceiving them. It does not directly target hardware or software, but instead it targets and manipulates people.

spear phishing A form of phishing in which the message is made to look as if it came from someone you know and trust as opposed to an informal third party.

tailgating Following someone through an entry point. **technical controls** Controls that rely on technology. **vishing** Combining phishing with Voice over IP (VoIP).

watering hole attack Identifying a site that is visited by those that they are targeting, poisoning that site, and then waiting for the results.

wetware Another term for social engineering.

whaling Phishing only large accounts.

bluejacking Involves sending unsolicited messages to Bluetooth devices when they are in range.

bluesnarfing Attack that involves getting data from a Bluetooth device.

BYOD Stands for Bring Your Own Device.

COPE Stands for Company-Owned and -Provided Equipment.

CYOD Stands for Choose Your Own Device.

EDGE Stands for Enhanced Data Rates for GSM Evolution. This does not fit neatly into the 2G/3G/4G spectrum. It is technically considered pre-3G, but it was an improvement on GSM (2G). So, we could consider it a bridge between 2G and 3G technology developed by the European Telecommunications Standards Institute (ETSI).

evil twin A rogue wireless access point that mimics the SSID of a legitimate access point.

GSM Global system for mobile communications. This is commonly known as 2G.

LTE Stands for Long-Term Evolution. This is a standard for wireless communication of high-speed data for mobile devices. It is what is commonly called 4G.

UMTS Stands for Universal Mobile Telecommunications Systems. This is a 3G standard based on GSM. It is essentially an improvement over GSM.

cold site A physical site that can be used if the main site is inaccessible (destroyed) but that lacks all of the resources necessary to enable an organization to use it immediately.

differential backup A type of backup that includes only new files or files that have changed since the last full backup. Differential backups differ from incremental backups in that they don’t clear the archive bit upon their completion.

disaster recovery The act of recovering data following a disaster in which it has been destroyed.

disaster-recovery plan A plan outlining the procedure by which data is recovered after a disaster.

failover The process of reconstructing a system or switching over to other systems when a failure is detected.

false positive A flagged event that isn't really a notable incident and has been falsely triggered.

forensics In terms of security, the act of looking at all the data at your disposal to try to figure out who gained unauthorized access and the extent of that access.

full backup A backup that copies all data to the archive medium.

hot site A location that can provide operations within hours of a failure.

incremental backup A type of backup that includes only new files or files that have changed since the last full backup and then clears the archive bit upon completion.

intrusion The act of entering a system without authorization to do so.

intrusion detection system (IDS) Any set of tools that can identify an attack using defined rules or logic. An IDS can be network-based or host-based.

intrusion prevention system (IPS) Any set of tools that identify and then actively respond to attacks based on defined rules. Like an IDS (which is the passive counterpart), an IPS can be network-based or host-based.

intrusive tests Penetration-type testing that involves trying to break into the network.

nonintrusive tests Penetration/vulnerability testing that takes a passive approach rather than actually trying to break into the network.

offsite storage Storing data off the premises, usually in a secure location.

onsite storage Storing backup data at the same site as the servers on which the original data resides.

snapshot Image of a virtual machine at a moment in time.

system image A snapshot of what exists.

tabletop exercise An exercise that involves individuals sitting around a table with a facilitator discussing situations that could arise and how best to respond to them.

vulnerability scanning Identifying specific vulnerabilities in your network.

warm site A site that provides some capabilities in the event of a disaster. The organization that wants to use a warm site will need to install, configure, and reestablish operations on systems that might already exist in the warm site.

working copy backup The copy of the data currently in use on a network.